

Security Assessment

- Organizations have different network security risks.
- A **posture assessment** checks all parts of the network to find weak points and should be done at least once a year.
- A **security audit** is done by a certified company to make sure the network follows security standards.

Security Risks

- ! • A **hacker** is someone who gets into systems without permission.
- ! • A **vulnerability** is a weakness in a system.
- An **exploit** is a method to use that weakness.
- A **zero-day attack** uses a vulnerability that hasn't been discovered yet. Most weaknesses are known, but zero-day ones are not.

Risks Associated with People



- **Half of all security violations**
 - Caused by human mistakes, lack of knowledge, or ignorances
- **Social engineering**
 - A method used to trick people into giving passwords
- **Phishing**
 - Tries to get access or login details
 - Pretends to be someone who needs information
- **Many people-related risks exist**
- **Easiest way to break network security**
 - Is to use human error

Risks Associated with Transmission and Hardware



- **Physical, Data Link, and Network layer risks**
 - Require advanced technical knowledge to exploit
- **Hardware and design-related risks**
 - **Transmission interception**(iletim yakalaması)
 - Includes jamming(engellenmesi) of communication signals
 - **RF emanation**(RF yayılımı)
 - Signals unintentionally leak from hardware, can be captured
 - **Eavesdropping**(Dinleme)
 - Happens when data passes over leased public lines (e.g., Internet)
- **Sniffing**
 - Data can be captured while traveling on public wireless networks
- **Port access via port scanner**
 - Attackers can find open or unused switch, router, or server ports
- **Private address exposure**
 - Happens if routers are not set to hide internal subnets properly
- **Router attack**
 - Occurs when routers fail to block suspicious or malicious packets



Risks Associated with Transmission and Hardware

- **Unsecured servers**
 - Access servers not secured and monitored
- **Sensitive data on same network**
 - Private computers share space with public ones
- **Weak passwords**
 - Easy to guess or default passwords are used
- **ARP table changes**
 - Hackers can change ARP to mislead network traffic



Risks Associated with Protocols and Software

- **Includes upper layers**
 - Transport, Session, Presentation, Application Layers
- Networking protocols and software risks
 - TCP/IP security flaws
 - Banner-grabbing attack
 - Session hijacking attack
 - Man-in-the-middle (MitM) attack
 - Invalid trust relationships
 - DHCP snooping
 - Dynamic ARP inspection (DAI)
- NOS back doors, security flaws
- Buffer overflow
- NOS allows server operators to exit to command prompt
- **Default security settings** by admins can be weak if not customized.
- Intercepting transactions between applications



Risks Associated with Internet Access (Common Internet-related security issues)

- **Web browsers** can run scripts that access user systems.
- **Users** should be cautious when giving personal info to websites.
- **Common internet security problems** include:
 - **Misconfigured firewalls:** may expose internal IPs (IP spoofing).
 - **Telnet and FTP use:** send usernames and passwords in plain text.
- **Improper firewall settings**
 - Outsiders can get internal IPs (IP spoofing)
- **Telnet and FTP use**
 - Sends username and password as plain text
- **Newsgroups, mailing lists, forms**
 - May expose user info to hackers
- **Chat session flashing**
 - Unwanted pop-up messages during chat
- **Denial-of-service (DoS) attack**
 - Hacker floods the network with fake ping traffi



Risks Associated with Internet Access

Four types of DoS attacks:

- **Distributed DoS (DDoS) attack**
 - Done by many infected systems (zombies) to flood a target
- **Distributed reflector DoS (DRDoS) attack**
 - Uses third-party systems to send back traffic to a victim.
- **Permanent DoS (PDoS) attack**
 - Damages the device permanently, usually through hardware access
- **Unintentional DoS attack**
 - Happens without bad intent, called a "friendly attack"

Security in Network Design

- **Weak LAN or WAN design can cause security breaches**
 - Solve this with smart network planning
- **Block outside access to LAN**
 - Limit access at all points where LAN connects to outside networks

NOS Security

- **Limit user access to server resources**(Restrict user authorization)
 - Control access to server files and folders
- **Public rights**
 - Given to all users
 - Very restricted access
- **Group users by security level**
 - Give extra permissions based on group

Logon Restrictions



- **Extra logon restrictions improve security**
 - Limit by time of day
 - Control total login duration
 - Check login source address
 - Lock after failed login attempts
- **Secure passwords**
 - Enforced by NOS to improve protection

Access Control Lists Used by Routers



- **Router's main roles**
 - Checks data packets
 - Finds the correct destination using network layer info
- **Access Control List (ACL)**
 - Also called access list
 - Used to block or allow specific packets

Access Control Lists Used by Routers

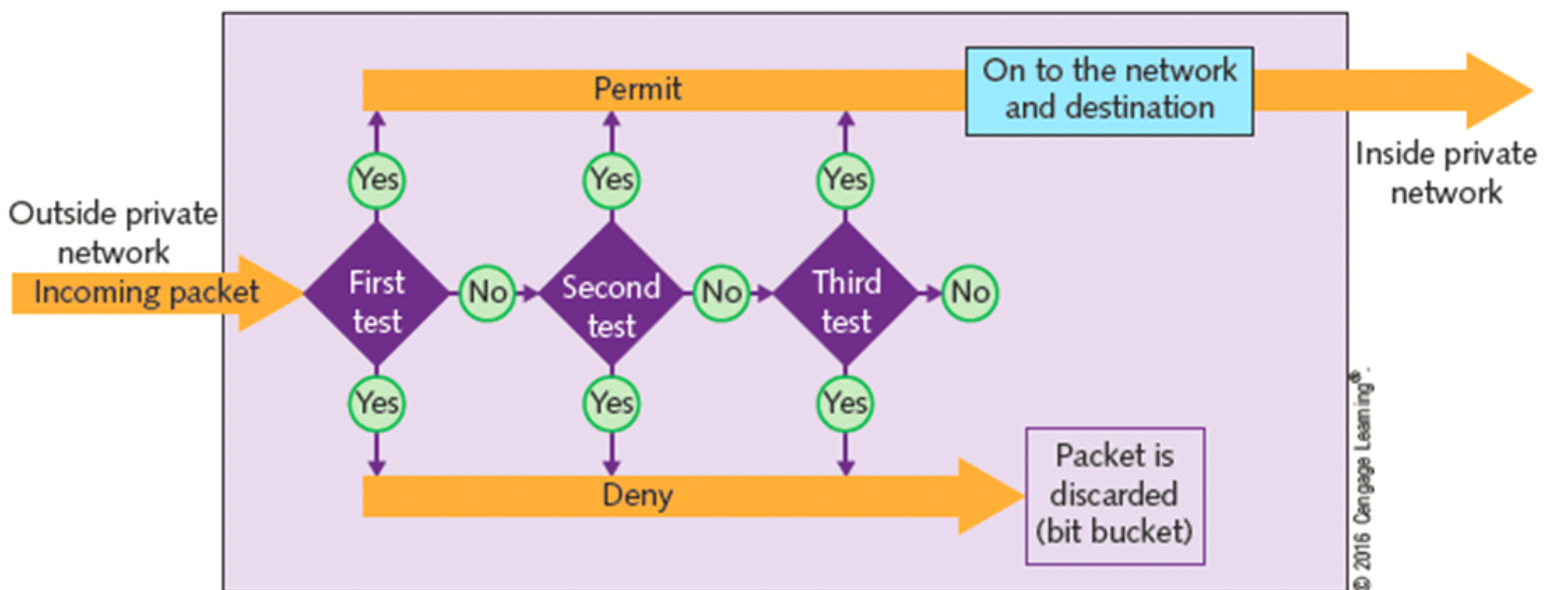


Figure 8-3 A router uses an ACL to deny or permit traffic to or from a network it protects

This diagram shows **how a router uses an ACL (Access Control List) to decide if a packet is allowed or not.**

- A packet comes from **outside the private network**.
- The router checks the packet with the **first test**.
 - If the rule says **"Yes"**, the packet is **allowed (Permit)** and goes to the destination.
 - If the rule says **"No"**, the router checks the **second test**.
- The second test does the same:
 - If **"Yes"**, permit the packet. If **"No"**, go to the **third test**.
- If the third test also says **"No"**, then the packet is **denied** and **discarded** (deleted).

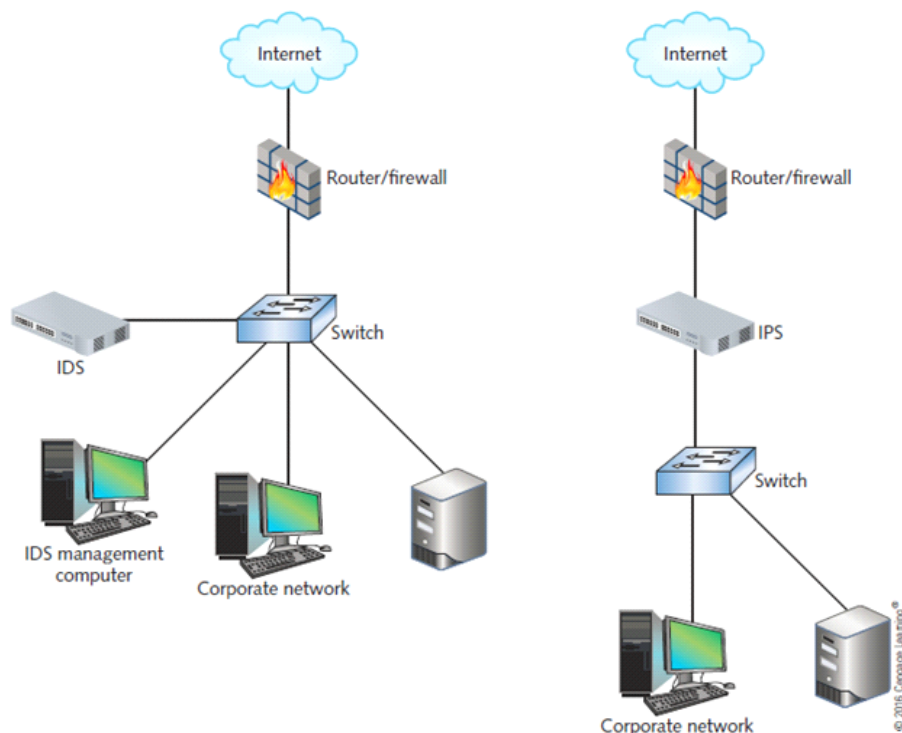
(repeat)

- **Router checks the packet:**
 - Uses ACL rules to allow or deny the packet.
 - **If packet matches a "deny" rule**, it is dropped.
 - **If packet matches a "permit" rule**, it is forwarded.
 - **If no rule matches**, the packet is dropped by default
→ This is called the **implicit deny rule**.
- **Each router interface needs its own ACL:**
 - Inbound and outbound traffic can have **different ACLs**.
- The access-list command adds a rule to an existing ACL.
 - You must include the ACL name and say if the traffic is **permitted** or **denied**.
- **Example:** To allow TCP traffic from 2.2.2.2 to 5.5.5.5:
 - access-list acl_2 permit tcp host 2.2.2.2 host 5.5.5.5
- **ACLs affect router performance:**
 - More rules or checks mean the router takes more time to process each packet.

Intrusion Detection and Prevention



- **Proactive security**
 - Detecting suspicious network activity
- **IDS (Intrusion Detection System)**
 - A software that checks network traffic.
 - Can run on:
 - A dedicated IDS device
 - A normal device doing other tasks
- **Port mirroring**
 - One port copies traffic and sends it to another port to be monitored.
- **Two types of IDS implementation**
 - **HIDS (Host-based IDS):**
HIDS (host-based IDS) works on one computer and sends an alert if that computer is attacked.
 - **NIDS (Network-based IDS):**
 - Protects a whole network
 - Usually placed at the network's edge or in the DMZ
- **Drawback of IDS**
 - May report many **false positives**
- **IDS limitation**
 - Can only **detect** and **log** suspicious activity — it doesn't stop it
- **IPS (Intrusion Prevention System)**
 - Takes action when it sees suspicious activity.
 - Stops dangerous traffic from reaching the network, using the source **IP address**.
- **NIPS (Network-Based IPS)**
 - Protects the whole network.
- **HIPS (Host-Based IPS)**
 - Protects specific individual devices.



This diagram shows the difference between **IDS** and **IPS** in a corporate network.

Key Difference:

- **IDS = Detects & alerts.**
- **IPS = Detects & blocks.**

IDS (Intrusion Detection System) !!

- It only **monitors** network traffic. !!
- It **sends alerts** to the IDS management computer when something suspicious is detected.
- It **does not stop** the traffic — just watches and reports.

IPS (Intrusion Prevention System)

- It **checks the traffic** before it enters the corporate network.
- It can **block or allow** traffic based on rules



Figure 8-4 An IDS detects traffic, and an IPS can detect and also intercept traffic to protect a corporate network

- corporate network.
- It can **block or allow** traffic based on rules
- it protects network, not just monitors it.

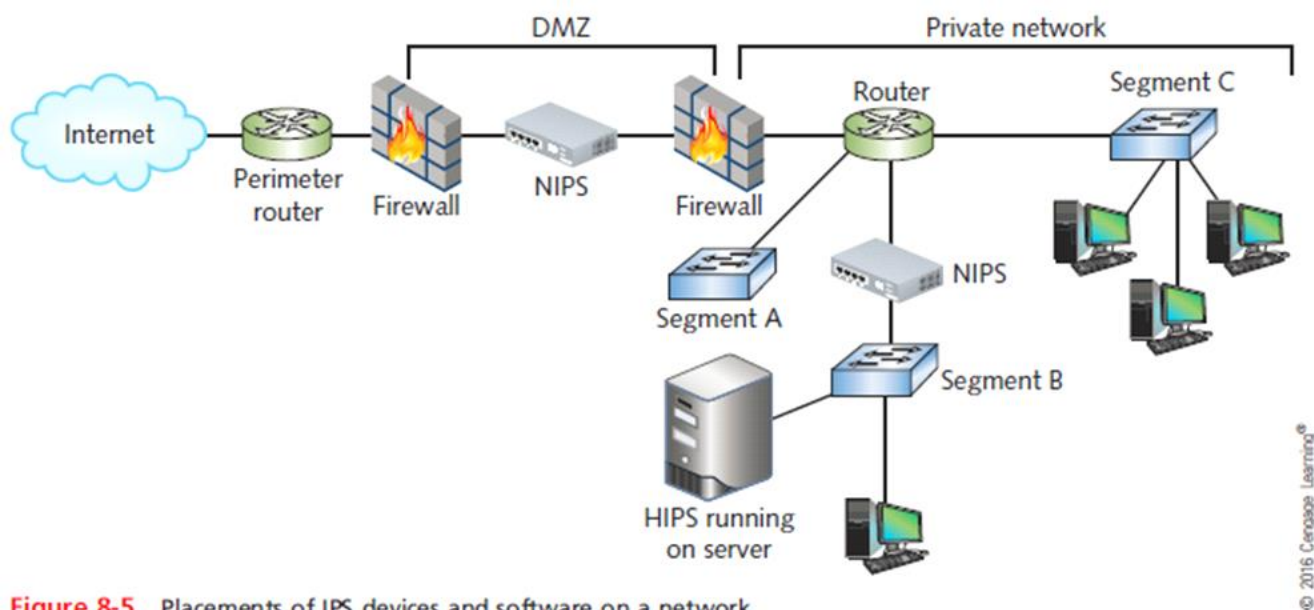


Figure 8-5 Placements of IPS devices and software on a network

© 2016 Cengage Learning®

This diagram shows **where IPS devices and software** can be placed in a network.

- **NIPS** protects large parts of the network (DMZ, Segment C).
- The **DMZ** area is monitored by a NIPS placed between two firewalls, protecting services accessible from the Internet.
- **HIPS** protects a specific machine (server in Segment B).
- **Firewall + Router** help control access between Internet, DMZ, and private network.

Firewalls

- **What is a firewall?**

A firewall is a special device or computer with software that controls traffic between networks.

- It blocks-filters or allows traffic based on rules.
- Usually includes both hardware and software.

- **Where is it used?**

- Between two connected private networks.
- Between a private network and the Internet (called a network-based firewall).

Firewalls Packet Filtering & Configuration

- **Packet-filtering firewall**

- Simplest firewall to use.
- Checks the header of every packet that enters (inbound).
- Can stop packets from entering or leaving the network (outbound).

- **Default firewall configuration**

- Blocks the most common threats.
- Comes with built-in rules to allow or block some traffic types.
- Network admins can customize settings.

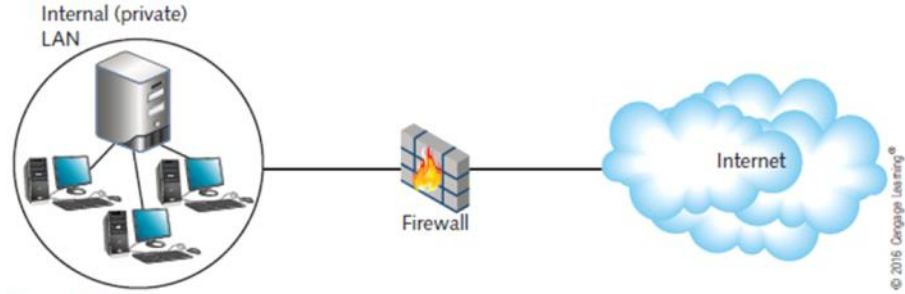


Figure 8-6 Placement of a firewall between a private network and the Internet

Common Criteria in Packet-Filtering Firewalls

- Source and destination **IP addresses**
- Source and destination **port numbers**
- **Flags** in the TCP header
- Use of **UDP** or **ICMP** protocols
- Whether the packet is the **first in a new stream** or part of an ongoing one
- Whether the packet is **entering (inbound)** or **leaving (outbound)** the private network

Firewalls – Extra Capabilities

- **Port Blocking**
 - Stops communication through specific ports to prevent connections and data transfers.
- **Optional Firewall Functions**
 -  **Encryption** – Protects data by converting it into unreadable form
 -  **User Authentication** – Verifies user identity before allowing access
 -  **Centralized Management** – One location to control multiple firewalls
 -  **Easy Rule Setup** –
 -  **Content Filtering** –

Proxy Servers

- **Proxy Service**
 - A software tool installed on a network device
 - Works as a **middleman** between external and internal networks
 - **Checks all traffic** going in and out
- **Proxy Server (Proxy)**
 - A network device that runs the proxy service
 - Handles security at the **Application layer**
 - Looks like a normal internal server to outsiders, but actually **filters and protects the internal LAN**

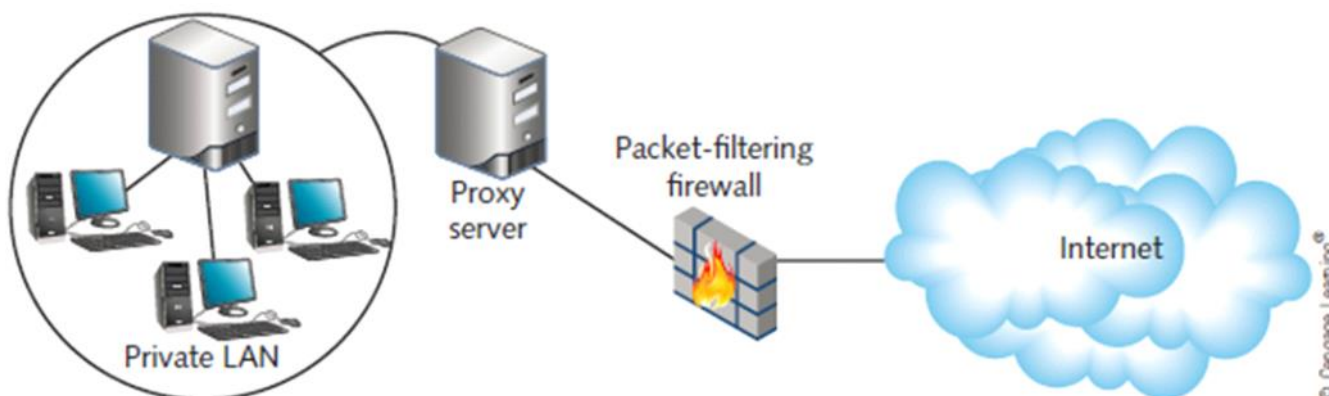


Figure 8-12 A proxy server used on a WAN